PROF. JEFFERSON RIBEIRO DE LIMA

AUDITORIA E SEGURANÇA DE SISTEMAS

SERRA
2010

Governo Federal
Ministro de Educação
Fernando Haddad

Ifes – Instituto Federal do Espírito Santo
Reitor
Denio Rebello Arantes

Pró-Reitora de Ensino
Cristiane Tenan Schlittler dos Santos

Diretora do CEAD – Centro de Educação a Distância
Yvina Pavan Baldo

Coordenadoras da UAB – Universidade Aberta do Brasil
Yvina Pavan Baldo
Danielli Veiga Carneiro

Curso de Tecnologia em Análise e Desenvolvimento de Sistemas
Coordenação de Curso
Andromeda Goretti Correa de Menezes

Designer Instrucional
Andreia Chiari Lins

Professor Especialista/Autor
Jefferson Ribeiro de Lima

Catalogação da fonte: Rogéria Gomes Belchior - CRB 12/417

L732a Lima, Jefferson Ribeiro de

Auditoria e segurança de sistemas. / Jefferson Ribeiro de Lima. – Vitória: Ifes, 2010.

82 p. : il.

1. Auditoria - Processamento de dados. 2. Processamento eletrônico de dados - Medidas de segurança. 3. Sistemas de recuperação da informação - Medidas de segurança. I. Instituto Federal do Espírito Santo. II. Título.

CDD 005.8

DIREITOS RESERVADOS
Ifes – Instituto Federal do Espírito Santo
Av. Vitória – Jucutuquara – Vitória – ES - CEP - (27) 3331.2139

Créditos de autoria da editoração
Capa: Juliana Cristina da Silva
Projeto gráfico: Juliana Cristina e Nelson Torres

Iconografia: Nelson Torres
Editoração eletrônica: Duo Translation

Revisão de texto:
Ilioni Augusta da Costa

COPYRIGHT – É proibida a reprodução, mesmo que parcial, por qualquer meio, sem autorização escrita dos autores e do detentor dos direitos autorais.

Olá, Aluno(a)!

É um prazer tê-lo conosco.

O Ifes – Instituto Federal do Espírito Santo – oferece a você, em parceria com as Prefeituras e com o Governo Federal, o Curso Tecnologia em Análise e Desenvolvimento de Sistemas, na modalidade a distância. Apesar de este curso ser ofertado a distância, esperamos que haja proximidade entre nós, pois, hoje, graças aos recursos da tecnologia da informação (e-mails, chat, videoconferência, etc.) podemos manter uma comunicação efetiva.

É importante que você conheça toda a equipe envolvida neste curso: coordenadores, professores especialistas, tutores a distância e tutores presenciais, porque quando precisar de algum tipo de ajuda, saberá a quem recorrer.

Na EaD – Educação a Distância, você é o grande responsável pelo sucesso da aprendizagem. Por isso, é necessário que se organize para os estudos e para a realização de todas as atividades, nos prazos estabelecidos, conforme orientação dos Professores Especialistas e Tutores.

Fique atento às orientações de estudo que se encontram no Manual do Aluno!

A EaD, pela sua característica de amplitude e pelo uso de tecnologias modernas, representa uma nova forma de aprender, respeitando, sempre, o seu tempo.

Desejamos-lhe sucesso e dedicação!

Equipe do Ifes

ICONOGRAFIA

Veja, abaixo, alguns símbolos utilizados neste material para guiá-lo em seus estudos

Fala Professor 

Fala do Professor

Conceitos 
Conceitos importantes. Fique atento!

Atividades 
Atividades que devem ser elaboradas por você, após a leitura dos textos.

Indicações 

Indicação de leituras complemtares, referentes ao conteúdo estudado.

Atenção 
Destaque de algo importante, referente ao conteúdo apresentado. Atenção!

Reflexão 
Reflexão/questionamento sobre algo importante referente ao conteúdo apresentado.

Atenção 
Espaço reservado para as anotações que você julgar necessárias.

Sumário

AUDITORIA E SEGURANÇA DE SISTEMAS

CAP 1 - AUDITORIA E SEGURANÇA DE SISTEMAS 11

1.1. Auditoria 12
1.1.1. Campo, âmbito e área. 12
1.2. Auditoria assistida 13
1.3. Auditor de sistemas 14
1.3.1. Papel do auditor de sistemas 14

CAP 2 - TIPOS DE AUDITORIA 17

2.1. Auditoria interna 17
2.1.1. Auditores internos 18
2.2. Auditoria externa 19
2.3. Auditoria articulada 20

CAP 3 - PLANEJAMENTO DA AUDITORIA 23

3.1. Planejamento para auditoria de sistemas 24
3.2. Avaliação dos controles internos 24
3.2.1. Natureza dos controles 25
3.2.2. Controle preventivo 25
3.2.3. Controle detectivo 25
3.2.4. Controle corretivos 25
3.3.Ponto do controle 26
3.4. Testes da auditória 26
3.4.1. Testes de conformidades 27
3.4.2. Testes substantivos 27
3.5. Relatório de auditoria 29
3.5.1. Modelo de um relatório de auditória 29

CAP 4 - CONTROLES INTERNOS 31

4.1. Definição 31
4.2. Tipos de controles 33
4.2.1. Controles administrativos 33
4.2.2. Controle de segurança 33
4.2.3. Controle para recebimento e entrada de dados 34
4.2.4. Controle do processamento 35
4.2.5. Controle de saída 35

4.2.6. Procedimentos de controle para sistemas de informação 36

CAP 5 AUDITORIA AUXILIADA POR SOFTWARES 39

5.1. Métodos 39
5.2. Ferramentas 40
5.2.1. Técnicas de auditoria e segurança de sistemas 44
5.3. Auditoria assistida por computador 45

CAP 6 - AUDITORIA DE HARDWARE E SOFTWARE 47

6.1. Auditoria de hardware 47
6.1.1. Objetivo principal do controle de hardware 48
6.2. Auditoria de software 48
6.2.1. Objetivo principal da auditoria de software 49
6.3. Controles internos dos softwares 50

CAP 7 - GESTÃO DO RISCO EM SISTEMA DE INFORMAÇÃO 53

7.1. Gestão de risco 53
7.2. Identificando riscos 53
7.3. Simulação de ataque 57

CAP 8 - PADRÕES DE PROCESSOS 59

8.1. Normas e padrões 59

CAP 9 - POLÍTICA DE SEGURANÇA DA INFORMAÇÃO 63

9.1. Política de segurança 63
9.2. Adoção da PSI 63

CAP 10 - ASPECTOS HUMANOS DA SEGURANÇA DA INFORMAÇÃO 67

10.1. Aspectos humanos 67
10.2. Equipe de segurança 68
10.3. Segurança do núcleo operacional 68
10.4. Engenharia social 69

CAP 11 - SEGURANÇA DO AMBIENTE 71

11.1. Segurança do ambiente físico 71
11.1.1. Proteção de documentos 72

11.1.2. Proteção de mídias 73
11.1.3. Proteção de hardware 73
11.2. Segurança do ambiente lógico 74
11.2.1. Proteção do ambiente lógico 74
11.2.2. Perímetro de segurança do ambiente lógico 76
11.3. Controle de acesso 76
11.3.1. Proteção do controle físico 76
11.3.2. Proteção do controle lógico 76

REFERÊNCIAS BIBLIOGRÁFICAS 79

APRESENTAÇÃO

Olá!

Meu nome é Jefferson Ribeiro de Lima,

sou responsável pela disciplina Auditoria e Segurança de Sistemas. Sou graduado em Tecnologia em Processamento de Dados e especialistas em desenvolvimento de sistemas em Java (UFES). Atualmente faço parte do grupo de pesquisa do Instituto Federal, voltado ao desenvolvimento de aplicações para dispositivos móveis, utilizando transmissão de dados sem fio.

Atuo como professor do Ifes há cinco anos e já lecionei em várias outras instituições de ensino técnico e superior. Tenho mais de dez anos de carreira como docente. Possuo vasta experiência em análise e programação de sistemas. Já prestei serviços para empresas de pequeno e grande porte, na região metropolitana da grande Vitória.

Sobre a disciplina, aprenderemos os conceitos e práticas, normalmente utilizados nas organizações para auditoria e segurança de sistemas, como também, identificaremos algumas ferramentas úteis para auxiliar no processo de levantamento e análise de dados.

Através da abordagem aplicada nesse material e seguindo os padrões que serão recomendados, você poderá desenvolver as competências necessárias para auditar sistemas e planejar a política de gestão de risco da tecnologia da informação.

Conheceremos inicialmente alguns conceitos e termos aplicáveis no processo da auditoria convencional. Em outro momento, vamos compreender o funcionamento das técnicas que serão aplicadas diretamente pela auditoria em sistemas. Para concluir, destaco os pontos relevantes da segurança e a gestão de risco.

O objetivo deste material é auxiliá-lo no estudo da disciplina, por meio de dicas, sugestões e exemplos práticos, destacando os pontos relevantes a serem estudados. Mas de qualquer forma, não dispensem a utilização de referências bibliográficas, pois elas acrescentam um maior aprofundamento e exemplos adicionais sobre o contexto de estudo.

Desejo sucesso a você!!!

Prof. Jefferson Ribeiro de Lima

Bons estudos!

CAPÍTULO 1

AUDITORIA E SEGURANÇA DE SISTEMAS

Fala Professor

Olá,

Neste capítulo você terá um primeiro contato com a disciplina de Auditoria e Segurança de Sistemas. A proposta inicial é apresentar os conceitos para trabalharmos posteriormente no estudo/execução da aplicabilidade das técnicas da auditoria nas organizações e na gestão da Tecnologia da Informação (TI).

Bons Estudos!
Prof. Jefferson Ribeiro de Lima

Atualmente as empresas buscam melhorias no processo da gestão de qualidade de produtos e serviços, tendo em vista a demanda crescente de consumidores mais exigentes. Para garantir que tudo funcione corretamente com eficiência e eficácia é necessário aplicar o processo de auditoria e segurança da informação. Desta forma, além de certificar a qualidade na execução do serviço, a empresa vai se prevenir contra acessos externos não autorizados no sistema de informação.

Esse conceito pode ser interpretado como mecanismo do exame dos procedimentos executados pelas empresas. Levando em consideração as ameaças que pode violar a confidencialidade, integridade e disponibilidade dos dados. É provável que qualquer falha na aplicação do conceito, coloque em risco o patrimônio ou própria existência da organização.

Conceitos

Confidencialidade:

Processo pelo qual as informações devem ser acessadas apenas por pessoas autorizadas.

Exemplo: Declaração de imposto de renda que é acessada apenas pelo contruinte ou pelo administrador do sistema da receita.

Conceitos

Integridade:

Processo pelo qual as informações devem ser mantidas de forma íntegra, a fim de garantir que os dados não sejam alterados ou excluídos por pessoas não autorizadas.

Exemplo: Conta de e-mail, ninguém pode alterar ou excluir, com exceção do próprio usuário.

Disponibilidade:

É o processo que garante a acesso as informações quando necessário.

Exemplo: Você pode ficar sem acesso a internet por causa de um problema no provedor.

1.1. Auditoria

Conceitos

Segundo Dias (2000), é uma atividade que engloba o exame das operações, processos, sistemas e responsabilidades gerenciais de uma determinada entidade, com intuito de verificar sua conformidade com suas regras, normas ou padrões.

Conforme o próprio conceito explica, auditoria é a análise minuciosa das operações. Portanto devemos aplica-lá nos processos que são realizados pelas pessoas nas empresas. Os processos são rotinas de trabalhos que normalmente são documentados, com a finalidade de direcionar a realização de uma ou várias atividades. Aos sistemas cabe gerenciar as operações e os processos nas organizações, no intuito de garantir a execução e o correto funcionamento dos procedimentos de acordo com as regras e normas estabelecidas para empresa.

1.1.1. Campo, âmbito e área.

Dentro da auditoria de sistemas, é necessário definir claramente os objetivos a serem alcançados, devido a isso devemos conhecer o campo, o âmbito e área que serão analisados.

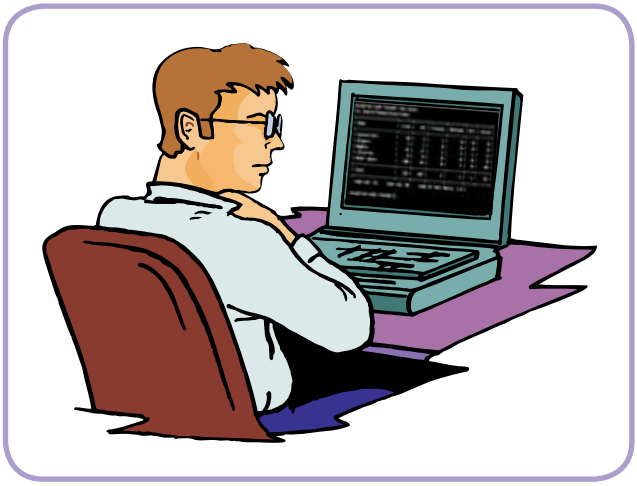
O campo define o que será fiscalizado, como também o tempo da execução do trabalho de auditoria e a sua finalidade.

No âmbito, serão definidos quais são os processos da empresa serão avaliados na auditoria.

Em relação área, podemos definir como dimensão dos trabalhos entre o conjunto do campo e âmbito, delineando o perímetro do trabalho. Através deste conceito é possível dimensionar a amplitude do trabalho da auditoria a ser desenvolvido, pois teremos a percepção exata dos setores e processos que serão abordados.

1.2. Auditoria assistida

É uma técnica que utiliza o computador para auditar os recursos e processos da empresa. Dessa forma, ganhamos agilidade no resultado dos exames efetuados por qualquer equipamento. O uso da automatização na análise dos processos é amplamente utilizado como parte da auditoria geral nas organizações.



Dentre os objetivos a serem alcançados podemos citar:

- Redução dos custos;
- Menor possibilidade de erros;
- Agilidade para análise dos processos.

1.3. Auditor de sistemas

Conceitos



Auditor:

Profissional responsável em efetuar o exame da auditoria. Possui competências e habilidades necessárias para avaliação e geração de laudos para certificação da empresa.

É o profissional responsável em efetuar a análise nos controles informatizados da entidade. É importante lembrar que a formação básica do auditor de sistemas é similar qualquer outro tipo de auditor, que é adquirir o conhecimento dos padrões internacionais para prática da auditoria. As principais mudanças encontra-se no exame das informações, que inicialmente era feita manualmente, agora também pode ser executada com auxilio de computadores.

Contudo devemos destacar que o auditor de sistemas nunca deve ser visto como um profissional isolado, pelo fato de trabalhar diretamente com ferramentas voltadas as tecnologias. O auditor de sistema pode ser visto como membro da equipe de auditores designada para levatamento e geração de resultados, sua função e oferecer suporte em decorrência dos avanços tecnológicos inseridos nas organizações.

O auditor de sistemas deve ser perspicaz e acima de tudo, deve possuir habilidades e competências para exercer da forma plena e objetiva o seu trabalho.

1.3.1. Papel do auditor de sistemas

O auditor de sistema realiza o controle do fluxo das informações computacionais para comprovar a efetividade dos programas, garantindo desta forma a integridade, confiabilidade e confidencialidade dos processos.

O auditor também tem o papel primordial na elaboração do plano de teste (o que será testando a nível computacional), checagem de rotinas sistêmicas (verificação e validação de dados fornecidos pelos sistemas da empresa) e diagnóstico das falhas ou vulnerabilidades encontradas na gestão da tecnologia da informação.

Para ser tornar um auditor de sistemas, são necessárias algumas habilidades como:

- Ser honesto e paciente;
- Possuir conhecimentos sobre as práticas da auditoria;
- Conhecer tecnologias diversas;
- Ter domínio das linguagens computacionais.

Para alcançar o objetivo de ser bom auditor, será necessário algum tempo de estudo e muita prática. Desta forma será possível atingir a excelência na prestação do serviço.



Fala Professor



Anotações

Atividades



Atividade 01

1) Responda:

a) Qual é a importância da auditoria nas empresas?

b) O processo aplicação dos métodos da auditoria pode variar conforme a empresa?

c) Podemos afirmar que os conceitos de segurança da informação são aplicados apenas nos sistemas computacionais?

d) Entre os conceitos aplicáveis na segurança da informação: confidencialidade, integridade e disponibilidade. Qual deles podemos destacar como o primordial?

e) Explique a diferença entre "auditoria" e "auditoria de sistemas?"

f) Podemos afirmar que o auditor de sistemas é um profissional de conhecimento específico? Por quê?

g) Defina quais são as atribuições de um auditor de sistema?

h) Cite alguns benefícios proporcionados pela auditoria assistida?

CAPÍTULO 2

TIPOS DE AUDITORIA

Olá,

Esse capítulo tem por objetivo definir as principais diferenças entres os tipos de auditoria interna, externa e articulada, com o intuito de fornecer o conhecimento necessário para aplicação da técnica na auditoria de sistemas.

Bons estudos!



Fala Professor

Conforme aprendemos no capítulo anterior, a auditoria é responsável pela análise das operações e processos das empresas, com objetivo de certificar e atestar a qualidade dos produtos ou serviços. Para se obter a certificação e necessário aplicar as normas do processo de gestão. E devido a esse fato, para atender aos padrões da qualidade, as auditorias são divididas em três partes:

- Auditoria Interna;
- Auditoria Externa;
- Auditoria Articulada.

A seguir, vamos entender a importância de cada tipo de processo e o seu contexto de aplicação.

2.1. Auditoria interna

A auditoria interna é definida como um processo da entidade, com objetivo de verificar a eficácia da mesma, ou seja, se os seus requisitos estão sendo atendidos na realização das atividades da empresa.

A auditoria interna atua na identificação de oportunidades de melhoria na execução e gerenciamento das tarefas executadas pelos funcionários, proporcionando a implementação de ações corretivas no sistema empresarial.

2.1.1. Auditores internos

O primeiro passo para aplicação da auditoria interna é selecionar o comitê gestor responsável.

Esse comitê é composto por uma equipe de funcionários de confiança da empresa. Os mesmos são selecionados por indicação da direção ou gerente da instituição. A função do comitê gestor é criar o ***manual da qualidade*** e acompanhar e fiscalizar as aplicação dos processos e procedimentos de trabalho.

Para ser auditor interno, o funcionário deverá participar de um treinamento ofertado pela empresa certificadora. A aquisição dessas competências e habilidades é primordial para o desenvolvimento e/ou construção do manual da qualidade que será utilizado na empresa.

Entre as funções do comitê, cabe destacar a criação das rotinas de trabalhos, bem como, efetuar o acompanhamento dos indicadores definidos no manual.

Através do acompanhamento e fiscalização os membros do comitê tomam as ações corretivas que poderão impactar diretamente nos procedimentos de trabalho dos funcionários.

Conceitos

Manual da qualidade – É o documento que descreve a gestão e funcionamento da empresa. Esse guia é gerado pelos auditores internos, com o suporte da empresa certificadora. Sua função principal é direcionar e padronizar as rotinas e processos internos de trabalho, para alcançar a excelência na prestação de serviços ou na produção de insumos.

Atenção

Dentro do contexto da auditoria a palavra **Procedimento** representa a descrição das funções exercidas pelas pessoas nas empresas. Podemos definir como rotina de trabalho diária. Através dessa descrição, qualquer funcionário poderá ser realocado ou substituído, pois o procedimento, norteia passo a passo como executar a tarefa para qualquer tipo de função.

2.2. Auditoria externa

É o exame minucioso das atividades desenvolvidas na empresa ou departamentos. Seu objetivo é checar se as diretrizes planejadas pelo manual da qualidade, estão sendo implementadas com eficácia, em conformidade com as suas normas estabelecidas.

Atualmente, a auditoria externa se distribui em diversas áreas de gestão, havendo várias ramificações como exemplo:

- Auditoria de sistemas;
- Auditoria de recursos humanos;
- Auditoria da qualidade e outros.

Os profissionais de auditoria são certificados e devem seguir rigorosas normas profissionais estabelecidas pela NBR ISO.



Figura 2 – Auditor certificado

A função do auditor externo é aplicar, de forma independente da entidade fiscalizada, as técnicas e normas estabelecidas com objetivo de emitir parecer sobre a gestão da empresa. O auditor deve ser ético e independente, seguindo a legalidade.

O auditor externo define criteriosamente as áreas que serão avaliadas para definir o planejamento da auditoria que será implementada na entidade. Através da análise dos pontos de controle, o auditor vai emitir seu parecer através do relatório final da auditoria.

Fala Professor

É importante ressaltar que o trabalho do auditor externo não se resume à confecção do relatório final de auditoria. O mesmo faz o acompanhamento e direcionamento nas instituições até a fase de avaliação final.

As considerações mais importantes devem ser destacas pelo auditor externo na avaliação final. Essas considerações podem definir se a empresa está em conformidade ou não para adquirir o certificado de qualidade total.

2.3. Auditoria articulada

É o trabalho conjunto realizado entre a auditoria interna e externa. Sua principal função é informar ao auditor externo sobre problemas já detectados na gestão da empresa. Desta forma o auditor externo fará a avaliação das ações preventivas, detectivas e corretivas aplicadas para sanar a falha.

O trabalho entre os auditores internos e externos é muito importante, principalmente para direcionar quais os pontos de controle necessitam de mais atenção.

Atenção

O auditor externo tem autonomia para definir quais são os pontos principais a serem investigados independemente da posição auditoria interna. Caso os achados da auditoria (documentos e processos analisados) não sejam satisfatórios, o auditor externo, poderá utilizar o relatório da auditoria interna como direcionador para execução do seu trabalho.

O auditor externo ao planejar a auditoria define junto ao comitê de auditoria interna a natureza e as áreas envolvidas para auditagem. Exemplo: Auditorias administrativa, contábil, financeira, legalidade, sistemas, operacional e outras. A todo o momento, existe a troca de informações entre os profissionais consultores externos e internos, na busca da solução que seja ideal para a instituição.

Será que é possível aplicar a solução atingida pelo processo de auditoria de uma empresa em outras?

É provável que não, mesmo que o ramo de segmento seja o mesmo, cada instituição tem as sua particularidade. Normalmente a empresa definirá seu perfil, ao iniciar o programa de gestão.



Reflexão

Atividade 2



Atividades

1) Responda:

a) Cite os tipos de autoria e explique suas diferenças.

b) Qual é a papel desempenhado pelo comitê gestor interno?

c) Podemos dizer que procedimentos são normas? Explique.

d) Quais são os processos passíveis de auditoria?

e) Comente a respeito da auditoria articulada e qual a sua finalidade.

f) Comente sobre a importância do trabalho da auditoria externa.



Anotações

CAPÍTULO 3

PLANEJAMENTO DA AUDITORIA

Olá,

Nesse capítulo vamos entender os conceitos para desenvolver o planejamento da auditoria. Esse planejamento é primordial para a execução e finalização do trabalho realizado pelo auditor.

Bons estudos!

Fala Professor

O planejamento da auditoria é a primeira fase do trabalho do auditor e deve ser realizada com uma visão técnica e bem estruturada, para garantir a eficiência nas fases posteriores.

Para efetivar esse planejamento, será necessário ter um conhecimento prévio da ***entidade*** a ser auditada. Desta forma, será possível estimar tempo, pontos importantes para investigar e pessoas que serão alocadas para o trabalho.

A palavra **entidade**, representa uma empresa (pessoa jurídica). Na verdade, existem diversos sinônimos para definir esse termo: entidade, empresa, organização e outros.

Atenção

Dentre as fases a serem destacadas no planejamento, podemos citar:

- Conhecer a empresa;
- Determinar escopo do trabalho;
- Definir recursos, prazos e pessoas;
- Definir cronograma para execução dos trabalhos.

3.1. Planejamento para auditoria de sistemas

Dentro do planejamento geral da auditoria, vamos encontrar uma subcategoria denominada sistema de informação. Da mesma forma que abordamos aspectos ligados às rotinas de controles internos, processos e procedimentos da empresa, se faz necessário analisar sistemas informatizados.

Para que a categoria (sistema de informação) seja abordada de forma adequada ao contexto geral da auditoria, será necessário checar a confiabilidade do plano de política de segurança da gestão de tecnologia da informação. Caso não haja credibilidade na política empregada, será necessário expandir o tempo de investigação do planejamento, criando-se métodos que possam atender a esse quesito primordial para o fluxo seguro das informações.

Na execução do planejamento é necessário criar o cronograma estimando tempo, demanda de profissionais e principalmente os setores e equipamentos que serão analisados.

3.2. Avaliação dos controles internos

A avaliação dos controles internos proporciona uma grande preocupação no processo de auditoria, qualquer que seja o seu objetivo.

Conceitos

Segundo a definição presente nas normas brasileiras para o exercício de auditoria interna: "Controles internos devem ser entendidos como qualquer ação tomada pela administração (assim compreendida tanto pela alta administração como nos níveis gerenciais apropriados) para aumentar a probabilidade de que os objetivos e metas sejam atingidas. Essas ações têm a finalidade de conferir precisão e confiabilidade aos dados contábeis, promover a eficiência operacional e encorajar a aderência às políticas administrativas prescritas".

3.2.1. Natureza dos controles

Podemos classificar a natureza dos controles de três formas:

- Preventivos;
- Detectivos ;
- Corretivos.

3.2.2. Controle preventivo

O controle Preventivo é utilizado na tentativa de eliminar erros, omissões ou fraudes antes da incidência. Sem dúvida podemos considerar o mecanismo de controle mais eficiente, pois evita os problemas antes que aconteçam.

3.2.3. Controle detectivo

O controle Detectivo serve para localizar erros ou fraudes no sistema da empresa. Possibilitando dessa forma a rápida intervenção ou eliminação de procedimentos não confiáveis.

3.2.4. Controle corretivos

Utilizados para correção de erros quando detectados. Desta forma o impacto sobre a instituição será menor, pois a falha foi prevista com antecedência.



Conceitos

Segundo Dias (2000), "o controle é a monitoração, fiscalização ou exame minucioso, que obedece a determinadas expectativas, normas, convenções sobre as atividades de pessoas, órgãos ou sobre produtos, a fim de não haver se desviarem das normas preestabelecidas".



Atenção

As técnicas de controles são aplicadas tanto no nível de instituição, bem como, na gestão de TI (Tecnologia da Informação). É importante frisar que antes de existência de um sistema computacional, já existe a empresa, que por sua vez promoverá procedimentos para uma padronização de sua rotina de trabalho.

3.3.Ponto do controle

Segundo Dias (2000), a situação do ambiente computacional deve ser considerada pelo auditor como sendo de interesse para validação e avaliação do processo de trabalho. Dentro da instuição, podemos determinar os pontos chaves para avaliação e levantamentos de informações pertinentes ao trabalho de análise investigativa do auditor. É importante ressaltar que pontos não considerados chaves, poderão ser reclassificados para uma possível ponto de controle.

Conceitos

Ponto de controle é o apontamento ou indicação dos setores e/ou procedimentos que serão avaliados a fundo pelo auditor. No primeiro momento, o auditor observa superficialmente a rotina da empresa, destacando, através do seu ponto vista, o que pode ser importante para uma análise futura mais aprofundada.

Através do ponto de controle é possível criar indicadores que vão auxiliar as possíveis mudanças ou melhorias na organização. Bem como, auxiliar o auditor, a gerar gráficos de áreas ou regiões críticas da entidade. Essas informações são essenciais na geração do relatório final da auditória.

Fala Professor

É importante entender que os controles, em sua ampla natureza, são diretamente relacionados aos documentos que serão confeccionados para padronizar a forma de trabalho da entidade. Seu uso também pode ser aplicado, como ferramenta de apoio ao trabalho realizado pela auditoria.

3.4. Testes da auditória

É possível atingir os objetivos da auditória utilizando dois tipos de testes.

- Testes de conformidade;
- Testes substantivos.

3.4.1. Testes de conformidades

São utilizados na tentativa de verificar a confiabilidade dos controles internos da organização. É normal que uma empresa já tenha sua rotina de trabalho, basta saber até onde essas rotinas são confiáveis, ou se realmente são efetivas. O auditor tem autonomia para efetuar testes através dos controles normalmente utilizados, no intuito de detectar possíveis falhas.

Quando o auditor encontrar algo que não está sendo executado, conforme descrito pelos próprios controles criados pela empresa, podemos dizer que o procedimento de trabalho gerou uma inconformidade.



Fala Professor

Inconformidade ou não conforme

Inconformidade quer dizer "não aceito". Esse termo é muito utilizado pela auditória para identificar processos ou procedimentos que não estão funcionando adequadamente.

A inconformidade gera problemas no controle das organizações. O principal papel do auditor e localizar esse problemas para auxiliar o processo de correção dos controles internos.



Conceitos

3.4.2. Testes substantivos

Os testes substantivos verificam os documentos específicos da organização. Como controles financeiros, livro caixa, balancetes e outros. O seu principal objetivo e checar a integridade das informações que possam afetar diretamente a vida financeira da empresa.



Figura 3 - Conferente

Podemos citar como exemplo, a análise do almoxarifado da organização, verificando alguns itens do mesmo para análise por amostragem. Desta forma, é possível quantificar se os dados de entrada lançados estão em conforme com os registros de saída.

Se o estoque possuir uma quantidade menor do que consta em registro, certamente existe falha no controle interno.

Fala Professor

Os controles internos são gerados pela própria entidade. Sua principal função é organizar / auxiliar a rotina de trabalho de cada setor ou grupo de trabalho.

Normalmente esse teste é realizado por um profissional que tenha habilidade em economia ou contabilidade, com conhecimento em informática, para analisar os dados que estão eletronicamente armazenados.

Certamente não será necessário que o auditor possua formação na área computacional, mas com o conhecimento mais aprofundado em tecnologia da informação, o trabalho será facilitado. Normalmente esse tipo de teste e realizado em conjunto por auditores com formação em suas respectivas áreas de conhecimento.

Os testes de conformidade e substantivos são importantes para a detecção de problemas e fraudes que possam ocorrer nas organizações.



Reflexão

3.5. Relatório de auditoria

É a fase final do trabalho de auditória. Esta etapa do processo, envolver a discussão e análise sobre os documentos aplicados ou recolhidos pelo comitê e gerência técnica responsável.

Tem como objetivo a definição por escrito do trabalho da auditoria, com o enfoque direcionado aos processos da organização.

É importante ressaltar que o relatório final da auditoria é um documento que deve ser concluído de forma independente e imparcial em relação à organização.

Esse relatório visa principalmente promover conhecimento sobre os fatos analisados ocorridos no intuito de esclarecer ou apontar possíveis melhorias no processo.

3.5.1. Modelo de um relatório de auditória

Um relatório de final de auditoria, normalmente agrega as seguintes informações:

1. Nome da organização, Data Inicial, Missão e objetivos;

2. Nome dos auditores;

3. Objetivos da Auditoria: Qual será a área abrangência, o que se deseja apurar e qual será sua finalidade;

4. Área de desempenho: Locais que envolvem maiores ou menos riscos na empresa;

5. Pessoas e Recursos: Pessoas que devem ser alocadas para a execução do trabalho, bem como, os instrumentos utilizados ou consumidos para análise;

6. Cronograma: Inclusão do cronograma e responsáveis pela execução do trabalho;

7. Lições aprendidas no processo da auditória.

Atenção



O modelo de relatório de planejamento não é padrão, pode ser definido de acordo com as necessidades de trabalho do auditor. Porém, é altamente recomendado que o relatório de planejamento possua informações importantes como objetivos e áreas críticas a serem avaliadas e outros.

Atividades



Atividade 3

1) Responda:

a) É possível efetuar auditoria sem planejamento? Por quê?

O que é uma entidade?

b) Dentre as fases do planejamento, qual é a mais importante e por quê?

c) Qual é a necessidade de alocar tempo no planejamento para análise dos sistemas informatizados?

d) Qual é a relação do controle interno com a tecnologia das informações?

e) Os controles preventivos, detectivos e corretivos são aplicados somente nos sistemas de informação? Comente.

f) Qual é o objetivo principal do ponto de controle?

g) A conformidade verifica a execução natural do procedimento. Comente o que é procedimento?

CAPÍTULO 4

CONTROLES INTERNOS

Olá!

A partir deste capítulo voltaremos a nossa atenção diretamente para auditoria de softwares. O conceito de controle interno, já era aplicável na gestão das empresas. Com a chegada da tecnologia da informação, esse conceito foi readequado para atender a nova filosofia de trabalho. Sua finalidade é definir uma política de organização e controle, a fim de proteger os ativos da organização.

Bons Estudos!

Prof. Jefferson Ribeiro de Lima



Fala Professor

4.1. Definição

Segundo Imoniana (2008), controle interno significa plano organizacional e coordenação de um conjunto de métodos e medidas adotados na empresa, a fim de salvaguardar o ativo (bens e direitos). Através desses conceitos é possível verificar com exatidão e veracidade os registros contábeis.

Com o crescimento da demanda do uso dos computadores pelas empresas, o conceito teve que ser readequado, pois inicialmente era feito da forma manual.

O controle interno na auditoria de sistemas inclui a verificações dos processos e a confirmação quanto a sua efetividade. Para garantir que esses processos sejam efetuados de forma plena, é preciso definir os princípios que brevemente serão destacados.

A seguir, citarei algumas recomendações dos princípios que devem ser adotados pelas organizações, na expectativa de garantir o controle interno aplicáveis aos recursos computacionais.

Supervisão

A empresa deve possuir ou capacitar um supervisor para a gestão da tecnologia da Informação.

Registros e comunicação

Quanto aos controles computacionais, a empresa deve definir procedimentos para distribuição, processamento e autorização de acesso aos dados.

Classificação de informação

Classificar a informação quanto ao seu grau de importância. Desta forma, podemos evitar que informações importantes da organização sejam acessadas por pessoas não autorizadas.

Auditoriabilidade

Efetuar constantes verificações nos procedimentos operacionais, para homologação das operações realizadas via sistema computacional.

Controle independente

Os sistemas devem garantir a execução dos procedimentos adequados para o reconhecimento e correção de erros de forma independente.

Monitoramento

Efetuar registro de acessos através de log's. O gerente deve ter livre acesso ao sistema, para efetuar o acompanhamento das ocorrências.

Atenção



O termo ***log*** é utilizando nos sistemas informatizados para gerar histórico das operações realizadas pelos usuários. Seu objetivo principal é informar para o administrador ou responsável pelo sistema, quais foram as operações realizadas por cada usuário a partir do seu acesso. Desta forma, é possivel saber quando o usuário incluiu, deletou, alterou ou acessou eventos no sistema. Através deste controle, é possível atribuir a responsabilidade por qualquer tipo de falha na operação por parte do usuário.

Projeto

É a parte vital dos princípios, pois é responsável pela definição do que vai ser feito, e como será feito o desenvolvimento, manutenção e implantação dos sistemas.

Plano de falhas

Também conhecido como plano de contingência ou plano B, é responsável pela ação a ser executada caso algo não funcione adequadamente. Qualquer tipo de irregularidade é tratada pelo plano de falhas, seja a nível organizacional ou de sistema.

4.2. Tipos de controles

Não há regra em relação aos tipos de controles informatizados. Isso pode variar de acordo com a sistemática do programa em operação.

4.2.1. Controles administrativos

Esse tipo de controle é responsável pela separação das responsabilidades e funções no sistema de gestão. Caso seja norteada erroneamente, a ocorrência de fraudes será inevitável, pois o gestor não terá como saber que foi o responsável pelo evento ocorrido.

Assim, o trabalho do gestor de controle administrativo é determinar as tarefas e atividades que são compatíveis para cada função. Desta forma, o sistema será desenhado para atender a necessidades específicas da empresa.

A responsabilidade da construção do sistema deve ser atribuída de preferência a terceiros, que não terão nenhum tipo de acesso às operações diárias do sistema, para evitar possíveis modificações na aplicação que possam ocasionar situações de fraudes. Os usuários finais jamais deverão ter acesso a informações sobre a documentação do software.

4.2.2. Controle de segurança

Sem dúvida nenhuma segurança é a palavra chave nas atuais organizações. Seja a nível estratégico, tático ou operacional, a segurança das informações é o grande motivo de preocupação na gestão das empresas. Com atual gerência dos dados sendo efetuada através de sistemas informatizados, tornou-se imprescindível à prevenção dos incidentes que possam causar danos a documentos vitais.

Segundo Imoniana (2008), os controles de segurança, outros que não aqueles que reduzem as pequenas ameaças e frequentes acontecimentos operacionais, em detrimento do funcionamento normal do sistema, são também concernentes às provisões de facilidade de backup.

Em outras palavras, um sistema de backup pode ser a solução para evitar possíveis perdas de dados em decorrência da má administração ou uso inadequado das informações contidas em meio eletrônico.

Atenção

Para criar uma rotina de backup (cópia de segurança dos dados), é aconselhável criar um mapeamento das informações primordiais da empresa por setor. Desta forma a cópia de segurança terá prioridade de armazenamento pelo grau de importância das informações.

4.2.3. Controle para recebimento e entrada de dados

É muito provável que a captação distorcida de dados ou mal recebida gere uma falha na integridade das informações que serão inseridas no sistema computacional. É fato que *inputs* (entradas) erradas, consequentemente gerarão *outputs* (saídas) erradas. Desta forma, o prejuízo pode ser grande para organização, trazendo aumento de custo, falta de credibilidade, e também, descrença dos próprios usuários na utilização do sistema.

Para minimizar erros na alimentação dos sistemas atuais, foram criadas rotinas para checagem, como, validação de dígitos verificadores, documentos pré-numerados para entrada de informações e outros. Mas isso não impede que erros possam ocorrer, principalmente pelo fato do trabalho de alimentação do sistema ser efetuado, na grande maioria das vezes, de forma manual. Por mais que os sistemas tentem checar a veracidade das transações através de inconsistências, existe a possibilidade de entradas incorretas no banco de dados.

Reflexão

Por mais atenção que um ser humano possa ter ao executar uma tarefa, após algumas horas de trabalho, seu raciocínio é afetado. Por isso, ao executar qualquer trabalho, efetue alguns minutos de parada a cada hora, para relaxamento. Isso pode ser aplicado também no momento do seu estudo. Ao executar uma atividade continuamente, você estará sujeito a sofrer uma estafa mental, ocasionando queda de desempenho.

4.2.4. Controle do processamento

A partir do momento que garantimos a entrada correta das informações, a partir da observação lógica, podemos analisar o resultado da transformação que será aplicado após o processamento.

Creio que seja muito óbvio saber qual será o resultado esperado após uma operação de soma entre dois valores, por exemplo. A mesma coisa ocorrer após a alimentação de um sistema de gestão, o gerente ou administrador da empresa normalmente tem um profundo conhecimento do retorno que deve ser visualizado após a transformação do dado primário em um dado secundário. O auditor de sistemas por sua vez, fará a entrada, buscando verificar a integridade, confiabilidade e disponibilidade do sistema de gestão.



Atenção

O controle de processamento nada mais é do que uma parte lógica do sistema computacional, responsável em receber e transformar o dado primário no resultado final. Para que isso ocorra, os gestores do sistema devem garantir que as informações de entrada sejam íntegras e confiáveis.

4.2.5. Controle de saída

Conforme já comentamos acima, não haverá uma saída correta caso não haja entrada correta. Na saída, teremos o resultado do processamento efetuado. Normalmente esse resultado é exibido através de relatórios ou gráficos. Para que essa informação não seja distribuída de forma desordenada a qualquer usuário é necessário que a entidade possua uma política de acesso aos dados. Desta forma, a empresa garante que apenas pessoas autorizadas terão acesso à informação.



Conceitos

Política de segurança é a expressão formal das regras pela qual é fornecido acesso aos recursos tecnológicos da empresa. Cada empresa define suas próprias regras, não existe padrão, porém algumas recomendações são vitais para garantir a segurança.

4.2.6. Procedimentos de controle para sistemas de informação

Dentro das organizações os procedimentos de controle de sistema serão avaliados pelos auditores, que normalmente, são pessoas com habilidades no trabalho com sistemas informatizados.

O processo de auditoria de sistemas é aplicado no contexto da auditoria geral da organização. Desta forma, a parte relativa da auditória de sistemas é apenas parte da gestão da auditoria na organização.

A análise do processo da auditoria no setor informatizado da empresa acontece a partir definição das metodologias que serão executadas pelo auditor. Em alguns momentos, esses métodos são similares da auditoria convencional utilizados nos processos gerais da organização. Porém, cabe ressaltar, que inicialmente e acreditando que o sistema computadorizado tem maior credibilidade nos testes relativos à veracidade e integridade das informações.

É conhecido que alguns testes aplicáveis a sistemas de informação, são frágeis, então, para evitar que o fato ocorra, o auditor define quais são os testes mais adequados para o plano de trabalho da empresa em questão. Esses testes são executados com auxílio de ferramentas de apoio para auditoria.

Atenção



Conforme já foi estudado anteriomente, procedimentos são rotinas de trabalhos que auxiliam na execução da rotina diária desenvolvida na empresa. Cada função ou atividade exercida, possui um procedimento definido.

.

Atividades

Atividade 4

1) Responda:

a) Quais são as principais recomendações sobre o princípio do controle interno computacional?

b) Qual é o papel do supervisor de gestão da tecnologia da informação dentro do contexto do controle interno?

c) Quais são os tipos de controles internos que podem ser aplicados no âmbito computacional?

d) Cite algumas vantagens ao utilizar sistemas computacionais para efetuar o controle interno nas organizações?

2) Relacione:

a) Acompanhamento das ocorrências.

b) Manuais para distribuição, processamento e autorização.

c) Constantes Verificações em procedimentos.

d) Reconhecimento e correção de erros.

e) Colaborador responsável para a gestão da tecnologia da informação.

f) Responsável pela definição do que vai ser feito.

( ) Monitoramento ( ) Projeto( ) Supervisão

( ) Controle independente ( ) Registros e comunicação

( ) Auditoriabilidade

CAPÍTULO 5

AUDITORIA AUXILIADA POR SOFTWARES

Olá!

Nesse capítulo vamos conhecer os programas utilizados pela auditoria e o papel de cada ferramenta para a captação, processamento e geração de resultado. Os programas que são utilizados como apoio aos trabalhos dos auditores são denominados softwares generalistas ou especialistas.

Bons Estudos!

Prof. Jefferson Ribeiro de Lima



Fala Professor

5.1. Métodos

Conforme comentado no capítulo anterior, algumas metodologias aplicáveis na auditoria convencional aplicam-se também na categoria de sistemas. Exemplo: questionários, observação da rotina de trabalho, exames de documentos e outros.

Os auditores também dispõem de uma técnica de auditoria assistida por computador, denominada (TAAC). Desta forma o processo de auditoria se torna muito mais ágil, devido ao aproveitamento dos recursos do software. Dentre as vantagens que podem ser destacadas, está o alto poder de processamento de operações simultâneas.

A técnica de TAAC pode ser aplicada para testes:

A) Controle de versão

Pode ser usada para controlar versões de softwares homologados para o funcionamento na empresa. Essa técnica é aplicada para garantir que a mesma versão de software seja usada por toda organização, evitando possíveis falhas ou inconsistências de informações.

B) Transações

Efetua simulação e calcula a sobrecarga das operações no processamento do sistema corporativo, levando em consideração as características de produção.

C) Análise de dados

Verifica inconsistências nos dados processados e armazenados pelas aplicações.

D) Simulação

Gera amostras para alimentação do sistema de informação da auditoria. É sem dúvida uma ferramenta essencial para testes.

5.2. Ferramentas

Vamos conhecer algumas ferramentas responsáveis para auxiliar o auditor na extração e manuseio dos dados.

Software generalista

É um conjunto de aplicações que pode efetuar processamento e **simulação paralela**. Ele pode gerar extração de dados para amostra, informações estatísticas, destacar possíveis registros repetidos entre outros.

Atenção



Simulação paralela – Termo utilizado pelo auditor de sistemas para efetuar testes em um sistema similar ao de produção. Normalmente é a mesma versão do sistema em produção, mas usando o banco de dados de teste. O auditor lança dados fictícios, no intuito de checar entrada, processamento, saída, anomalias ou eventos gerados no software.

Alguns tipos de softwares generalistas:

Pentana: software de planejamento estratégico da auditoria, sistema de planejamento e monitoramento de recursos e gerenciamento de plano de ação;

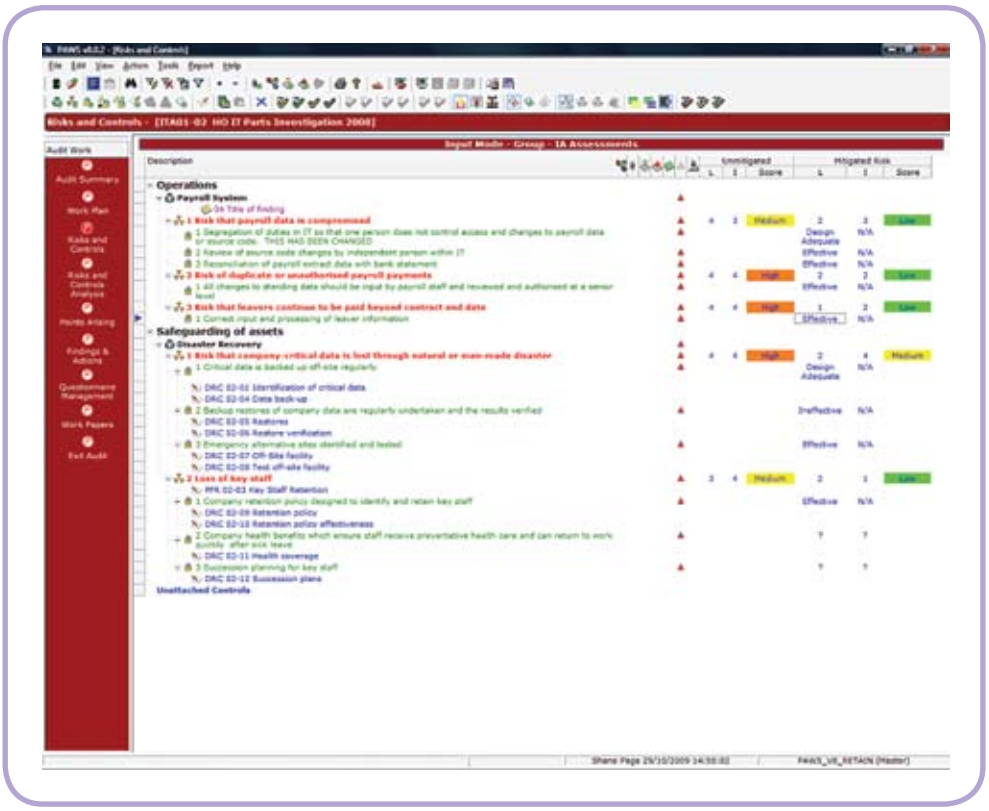


Figura4 - Software PAWS, baseado no Pentana

IDEA (Interactiva Data Extraction & Analysis): software para extração e análise de dados;

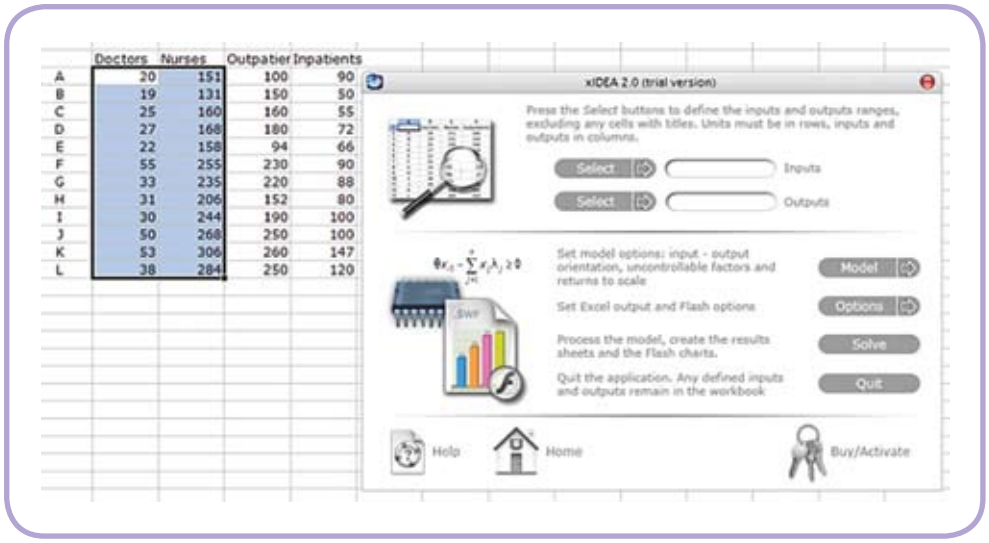


Figura 5 - software xIDEA

Galileo: software integrado de gestão de auditoria. Inclui gestão de riscos de auditoria, documentação e emissão de relatórios para auditoria interna;

ACL (Audit Command Language): é um software de extração e análise de dados;

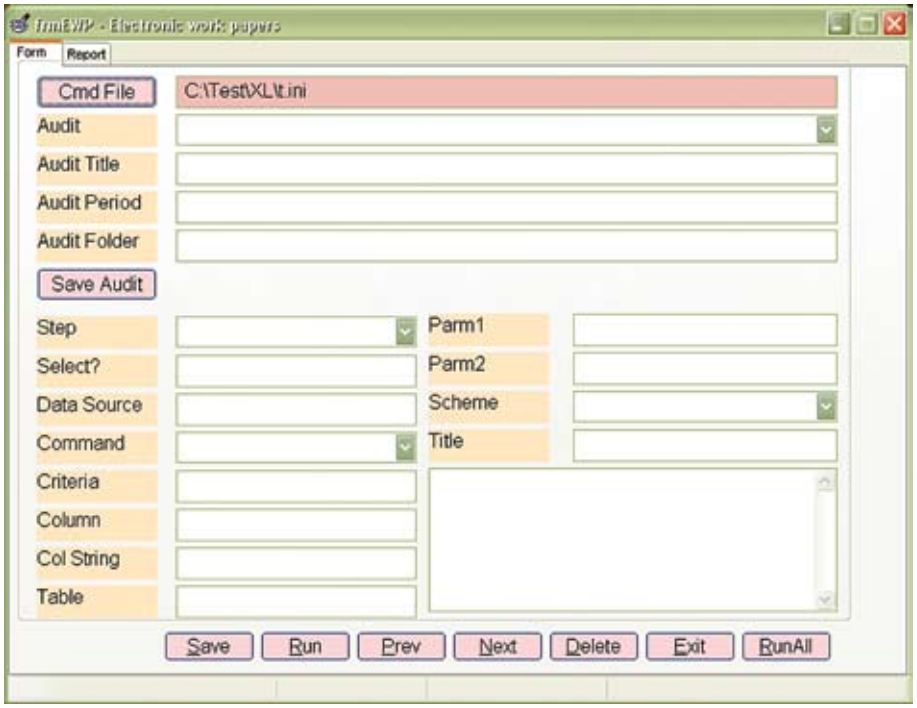


Figura 6 - Software Eletronic Workpaper, baseado no conceito de ACL

Audimation: Solução de monitoramento continua, desenvolvido para atender a demanda da gestão de risco. Dentre as suas principais funções destacamos: Exame de operações, relatório de exceções e documentação de resultados.

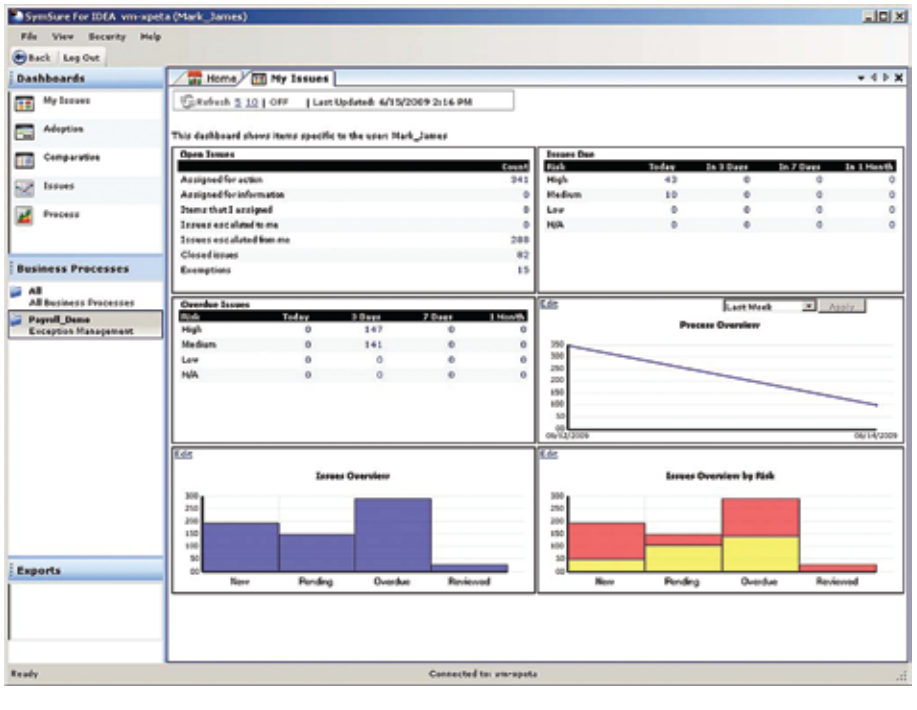


Figura 7 – Software vm-xpeta (Audimation)

A maioria das aplicações generalistas citadas são soluções proprietárias. Para utilizar, você deverá adquirir uma licença de uso do software.

Atenção

Softwares especialistas

É um programa desenvolvido especificamente para executar certas tarefas dentro do contexto da auditoria. A desvantagem desse tipo de software é o alto custo de desenvolvimento e será limitado para utilização específica para uma organização.

Utilitários

São ferramentas de apoio para o auditor realizar alguns tipos de operações comuns como: concatenação, classificação, geração de gráficos e outros. Esses programas não são desenvolvidos com o fim específico para auditoria, mas são extremamente úteis nas mãos do auditores. Podemos citar como exemplo, a planilha Excel.

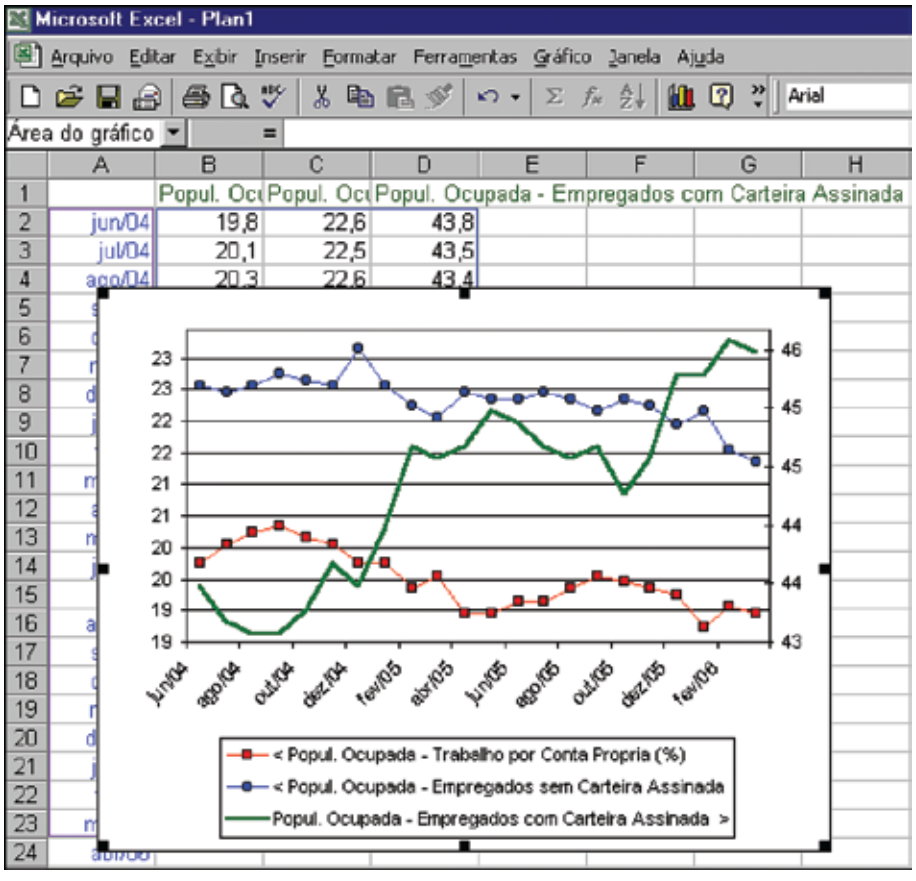


Figura 8 – Software Excel (planilha microsoft)

5.2.1. Técnicas de auditoria e segurança de sistemas

Existem diversas técnicas aplicáveis para auditoria de sistemas, a seguir destacarei algumas que considero mais relevantes no processo. Normalmente a aplicação da técnica é definida no processo de planejamento da auditoria, devido a esse fator, não é considerada regra para qualquer tipo de instituição. Antes de indicar a técnica, leve em consideração aspectos como objetos e escopo da organização auditada.

Test-deck

Método que consiste na inserção dados no programa em operação. Através desta inserção, é possível checar se existe a validação para dados incompletos. Um exemplo dessa situação seria a tentativa de incluir uma senha fraca como 12345; o sistema deve efetuar "criticar" nesta situação.

Teste de recuperação

Avalia a capacidade de recuperação do sistema quando existir qualquer espécie de falha ou erro crítico no sistema em operação. Os procedimentos de recuperação automática devem se desenvolvidos para efetuar a restauração da aplicação a qualquer custo.

Teste de desempenho

Verifica o consumo de recursos computacionais e o tempo de resposta das operações requisitadas ao sistema de informação. É necessário criar ou usar software de terceiros para efetuar a medição.

Teste de stress

Avalia o funcionamento do sistema em operação quando submetido a condições de funcionamento extremo. Um exemplo disso seria utilizando um grande volume de dados no banco ou tentar realizar vários acessos simultâneos na aplicação.

Teste de segurança

Avalia os mecanismos de segurança do sistema sobre os conceitos prevenção, detecção e correção.

Teste da caixa preta

Consistem em avaliar os requisitos funcionais dos sistemas em operação. Condições de entrada, interface, acesso à banco de dados e outros.

Teste da caixa branca

Avalia a estrutura interna do programa desenvolvido, em outras palavras, faz a análise do código fonte do sistema. Normalmente é feito pelo auditor perito em programação, pois o mesmo avaliará a situação do controle de fluxo do código, como estrutura de repetição, loops, operações matemáticas, funções e outros.

5.3. Auditoria assistida por computador

Alguns passos importantes devem ser levados em consideração para aplicação da auditoria assistida por computador.

- Estabelecer objetivos;
- Definir os bancos dados e aplicações a serem testadas;
- Entender o modelo de dados;
- Definir testes e procedimentos;
- Certificar que os processos de TAAC;
- Avaliar os resultados obtidos.

Atividade 5



Atividades

1) Complete com o método mais adequado:

a) Essencial para efetuar teste para auditoria:

_____

b) Calcula a sobrecarga das operações de processamento:

_____

c) Checa inconsistências de dados:

_____

d) Técnica aplicada para efetuar o controle de versão:

_____

Atividades



2) Responda:

a) Por que a simulação paralela é importante? Comente.

b) Cite três tipos de softwares generalistas?

c)Quais são diferenças destacadas entre o software generalista e especialista?

d) Pesquise exemplos de softwares utilitários que podem ser utilizados pelo auditor?

3) Relacione:

a) Test-desk	( ) Análise do funcionamento do sistema em condições extremas, como grande volume de operações e dados.
b) Teste de recuperação	( ) Mecanismo de segurança do sistema como senha, criptografia e outros.
c) Teste de desempenho	( ) Avalia requisitos funcionais do sistema.
d) Teste de stress	( ) Consiste na inserção de dados no programa em produção e efetua validação.
e) Teste de segurança	( ) Checa a capacidade de recuperação do sistema as falhas.
f) Teste da caixa preta	( ) Verifica o consumo de recursos computacionais e tempo de resposta
g) Teste da caixa branca	( ) Análise do código fonte do sistema.

CAPÍTULO 6

AUDITORIA DE HARDWARE E SOFTWARE

Olá!

Neste capítulo vamos estudar as formas para aplicação da auditoria nos equipamentos e programas utilizados nas organizações, a fim de proteger o patrimônio físico e intelectual da empresa.

Bons estudos!

Prof. Jefferson Ribeiro de Lima

Fala Professor

6.1. Auditoria de hardware

A auditoria de hardware é realizada com o objetivo de assegurar a segurança e funcionamento dos equipamentos distribuídos na organização. Também auxiliará o monitoramento para o uso adequado por parte dos usuários, através do uso correto dos procedimentos. Esse procedimento pode ser físico ou automatizado.

Quando físico, irá implicar na elaboração de várias regras de orientação do usuário que fará uso do equipamento. Já no processo automatizado, implicará apenas no acompanhamento das rotinas definidas pelo fabricante, executadas da forma sistêmica pelos usuários. Aplicando-se essas práticas, fica mais fácil descobrir possíveis falhas na gestão do hardware.

Para os auditores, o controle do hardware, é a certificação do correto manuseio dos equipamentos. Caso não haja procedimentos adequados para uso, o trabalho da auditoria fica prejudicado, consequentemente acarretará uma não conformidade.

Como consequência dessa ação, não será possível aplicar controles corretivos, ocasionando uma parada critica em diversos setores da empresa.

Segundo Imoniana (2008), "a padronização dos equipamentos na empresa é um procedimento fundamental para auxiliar na implementação do controle efetivo".

As empresas, preferencialmente, devem optar pela utilização de equipamentos do mesmo fabricante e modelo, para garantir compatibilidade e agilidade no processo de manutenção.

Contudo, também devem possuir um controle de patrimônio eficaz a fim de evitar possíveis roubos de peças ou trocas de equipamentos, para isso é necessário definir procedimentos que efetuem os registros de entrada e saída de qualquer dispositivo manipulado na organização.

6.1.1. Objetivo principal do controle de hardware

Com certeza podemos citar que o objetivo principal é assegurar que pessoas não autorizadas não tenham acesso aos meios físicos e principalmente às informações contidas nesses meios.

Através do checklist (lista de checagem) é possível definir quais são os tipos de equipamentos e autorizações concedidas aos usuários. A lista de checagem deve uma espécie de leitura de mão para os colaboradores.

O checklist também é amplamente utilizado por setores de manutenção e suporte aos usuários. Através da lista é possível verificar e testar as causas de problemas diversos, relacionados às aplicações ligadas aos hardwares ou softwares.

6.2. Auditoria de software

O objetivo da auditoria de software é auxiliar na elaboração de procedimentos para utilização correta dos aplicativos e serviços lógicos disponíveis nos equipamentos da empresa. Normalmente as empresas possuem um serviço de monitoramente que são acionados juntamente ao ativar o sistema operacional do equipamento.

Através do serviço de monitoramento, é possível assegurar que serão executados somente aplicativos que estejam de acordo com a regulamentação definida pela organização. O auditor deve ter conhecimento de todo funcionamento das operações para sugerir as práticas de uso das aplicações e restrições de acessos por parte dos usuários.

É importante criar procedimentos de controles corretivos para intervenções no ambiente de processamento de dados, pois as mesmas têm impacto direto nas operações diárias que podem ocasionar prejuízos para as organizações.

6.2.1. Objetivo principal da auditoria de software

É garantir que os processos operacionais da gestão de TI sejam executados sobre as normas e padrões estabelecidos para o correto processamento das tarefas, como também objetiva, avaliar a confidencialidade, privacidade, acuidade, disponibilidade e manutenção dos sistemas. Para isso, serão definidos controles das operações que devem ser executadas pelos softwares, principalmente quando envolver processamento de transações econômicas ou financeiras.



Atenção

A parte de auditoria de harware e software, normalmente é executada por um conjunto de auditores especializados na gestão de TI, com suporte de outros consultores especilistas em suas áreas afins.



Conceitos

Segundo Imoniana (2008):

Integridade – Confiança nos dados informados, pelo processamento ou transações;

Confidencialidade – Informações reveladas apenas para pessoas autorizadas;

Acuidade – As transações processadas podem ser validadas, atentando a sua veracidade;

Disponibilidade – A essência da disponibilidade é que o sistema esteja disponível quando requitado.

Auditabilidade – Os sistemas devem efetuar logs operacionais que permitam acompanhamento dos eventos efetuados;

Versatilidade – Sistema amigável e flexível, podendo ser facilmente adaptado os workflows operacionais da empresa;

Manutenilibilidade – As políticas e procedimentos operacionais contemplam tanto controles quanto a testes, conversão, implementação e documentação de sistemas novos ou modificados.

6.3. Controles internos dos softwares

Os procedimentos de controles de sistema são essenciais para o diagnóstico dos pontos fracos que poderão acarretar falhas na segurança da informação na entidade.

Devido a esse fato, é de suma importância para o auditor, o conhecimento prévio das operações e funções inseridas no sistema, bem como, o conhecimento do fluxo de execução/transação com outras aplicações de uso corporativo.

Alguns controles são recomendados para garantir uma maior eficiência e eficaz na gestão dos softwares nas instituições.

Seguem abaixo algumas recomendações:

- Definição de perfil de acesso (Quais os direitos de uso para cada usuário);
- Atribuição de funções definidas aos usuários do sistema;
- Verificação de tempo de acesso;
- Acompanhamento dos eventos por usuário (Passos do usuário no sistema);
- Dispositivo lógico de segurança ativo (antivírus, firewall);
- Restrição de instalação de software;
- Suporte especialista em softwares.

Atenção



Recomendações são práticas funcionais testadas e aprovadas que indicam o chamado "caminho das pedras". Através das recomendações, grande parte do esforço efetuado pelo auditor pode ser poupado.

Desta forma, além de ofertar benefícios organizacionais, reduzirá o tempo de auditoria, e consequentemente, o custo para execução deste trabalho.

Após análise dos controles, o auditor criará um relatório que vai contemplar os objetivos e finalidades de cada teste, no intuito de atestar a credibilidade dos documentos gerados pelo processo.



Atividades

Atividade 6

1) Responda:

a) Quais são as vantagens da padronização dos equipamentos utilizados pelas empresas?

b) Qual é a importância do controle patrimonial de hardwares nas empresas?

c) Escreva um procedimento para controle patrimonial de hardware ?

d) Como evitar possíveis falhas de segurança na gestão do hardware?

e) Como a *checklist* pode ajudar o setor de manutenção? Dê um exemplo.

f) Como podemos acompanhar no nível de software as ações efetuadas pelos usuários?

g) Dê um exemplo da aplicação do controle corretivo para software?

h) Qual é a importância do conhecimento prévio do auditor sobre as operações e funções inseridas no sistema corporativo?

Anotações



CAPÍTULO 7

GESTÃO DO RISCO EM SISTEMA DE INFORMAÇÃO

Olá!

No capítulo a seguir, o foco será direcionado para segurança da informação. Você aprenderá a evitar possíveis ameaças de segurança que possam prejudicar o equilíbrio dos negócios e o funcionamento da empresa. Os conceitos que serão evidenciados representam uma valiosa contribuição para o desenvolvimento da política de segurança, aplicada na gestão empresarial.

Bons estudos!

Prof. Jefferson Ribeiro de Lima



Fala Professor

7.1. Gestão de risco

A gestão de risco pode ser evidenciada como conjunto de mecanismos que permite à empresa identificar e implementar tomadas de decisões em prol da proteção dos ativos da informação. Consequentemente, minimizando os riscos, mantendo a filosofia de confidencialidade, integridade e disponibilidade de acesso aos dados, sem prejuízos para a entidade.

Segundo a ISO guide 73, gestão de risco é a atividade que direciona e controla uma organização com relação aos riscos. A gestão de risco normalmente inclui avaliação, tratamento, aceitação e comunicação dos mesmos.

Conceitos

7.2. Identificando riscos

Processo de localização é avaliação dos elementos de risco.

Análise do risco

Para a definição do risco é necessário conhecer os dados históricos da orga-

nização para identificar os pontos fontes e fracos da entidade. O estudo desta etapa, direciona o auditor na busca das soluções para minimizar as falhas.

Avaliação do risco

Nesta etapa é feita uma comparação entre risco estimado e critério de risco. Através dessa comparação, é possível determinar a importância do risco, que por sua vez pode ser aceitável ou deve ser tratado.

Estimativa do risco

A estimativa de risco, atribui peso para a probabilidade e as consequências de risco eminente. Não existe um critério fixo para determinar esse valor atribuído. Mas é importante levar em consideração na hora da atribuição dos valores, quais são os eventos primordiais para o funcionamento da empresa.

Análise e avaliação do Risco

O estudo da gestão de risco tem início a partir da identificação dos elementos eminentes como: alvos, agentes, ameaças, vulnerabilidade e impactos.

Conceitos

Definições segundo a ISO guide 73.

Alvo: Ativo de informação que pode ser objeto de um ataque/ incidente.

Exemplo: base de dados, hardware, sistema de informação, etc.

Definições segundo a ISO guide 73.

Agente: Fonte produtora de um evento que pode ser efeitos adversos sobre ativo da informação.

Exemplo: funcionários, meio ambiente, hackers, etc.

Ameaças: expectativa de acontecimento acidental ou proposital, causado por um agente, que pode afetar o ambiente, sistema ou ativo da informação.

Vulnerabilidade: Fragilidade que poderia ser explorada por uma ameaça para concretizar um ataque.

Impacto: Efeito ou consequência de um ataque ou incidente para a organização.

Segundo Beal (2005), "as ameaças a que se sujeitam às informações e os ativos da informação podem ser classificadas como ambientais(natural, fogo, água, etc), técnicas (configuração incorreta de componentes de TI, falha de Hardware ou software), lógicas (código maliciosos, invasão de sistemas) e humanas (erro de operação, fraude e sabotagem)".

É fato que essas ameaças estão presentes no dia a dia das empresas, é função do auditor, auxiliar para evitar que os eventos maliciosos ocorram atingindo os alvos de ataque.

A seguir, conheceremos a tabela que identifica as ameaças e os tipos de riscos nas organizações. Ela é utilizada como apoio pelos auditores internos, na identificação dos riscos, com o intuito de prover diretrizes para a confecção da política de segurança da organização.

Através da gestão de risco, vários processos serão contemplados a partir do levantamento e avaliação dos setores. Isso não é aplicado somente para sistemas de informação, mas para salvaguardar o ativo da empresa (bens e direitos).



Fala Professor

Tabela – Segue alguns tipos de ameaças que podem ocorrer nas entidades.

Ameaça	Recurso vulnerável	Impacto para confidencialidade	Impacto para integridade	Impacto para disponibilidade
Falha de equipamento	Todo o hardware	O equipamento danificado pode ser enviado para manutenção com dados sigilosos	Dados podem ser corrompidos no momento da falha	Serviço indisponível
Erro Humano	Sistemas em geral	Divulgação de informações de forma acidental	Inserção de dados incorretos por funcionários	Destruição acidental de dados por parte dos funcionários
Equipamentos pessoais	Hardwares pessoais conectados a rede da empresa	Inserção de vírus ou cavalo de tróia na rede	Dados podem ser corrompidos ou furtados	Dados importantes podem ser apagados e computadores servidores deixar de funcionar
Desastres naturais	Edifício, meio de comunicação (redes, telefone, etc).			Todos os serviços ficarão temporariamente paralizados
Furto	Hardware	Equipamentos podem conter informações valiosas		Serviço pode ser interrompidos
Furto de informações	Acesso a sistemas	Acesso de pessoas não autorizadas	Dados poderão ser modificados	Informações sem credibilidade

Indicações



Uma boa fonte de pesquisa para complementar os seus estudos sobre gestão de riscos, tratado nessa seção, é o livro, Segurança da Informação, de Adriana Beal, editora Atlas, 2005.

7.3. Simulação de ataque

A função principal do teste de simulação de ataque é verificar o nível de proteção da segurança da informação existente nas organizações. Através dessa metodologia, é possível simular ataques internos e externos que ocorram no ambiente empresarial, como varredura da rede interna ou até mesmo o grau de conscientização dos usuários em relação às possíveis ameaças.

Os testes podem incluir, análise da estrutura da fragilidade da rede ou tentativa de invasão ao sistema de informação, simulando o hacker. Também e muito comum aplicar o teste de engenharia social, com objetivo de detectar possíveis usuários vulneráveis a revelar senhas ou outros dados que possam comprometer de forma direta ou indireta a empresa.



Conceitos

O termo Engenharia Social é o meio mais utilizado para obtenção de informações sigilosas e importantes. Isso porque explora com muita sofisticação as "falhas de segurança dos humanos". As empresas investem fortunas em tecnologias de segurança de informações e protegem fisicamente seus sistemas, mas a maioria não possui métodos que protegem seus funcionários das armadilhas.

Para tratar o risco, segue um exemplo de medidas preventivas.

Ameaça	Medidas Preventivas	Medidas detectivas	Medidas Reativas
Furto de equipamentos	Controle de equipamentos	Registro de patrimônio, com revisões periódicas.	Investigação e denúncia
Falta de energia	Instalação de no-break para os servidores	Checagem das baterias e tempo de validade das mesmas.	Caso o tempo de validade esteja expirado, efetuar substituição do equipamento.

Tabela 1.2 – Plano de contingência por ameaças

Atividades



Atividade 7

1) Responda:

a) Cite exemplos de riscos eminentes aos sistemas das corporações?

b) Quais são os alvos mais prováveis de ataques nas empresas?

c) Ameaças ligadas ao hardware podem ocasionar que tipo de prejuízo para instituição?

d) Qual é a importância da simulação de ataque?

e) Qual é a finalidade da tabela de análise de risco?

2) Destaque a opção incorreta.

a) Impacto: Efeito ou consequência de um ataque ou incidente para a organização.

b) Agente: Fonte produtora de um evento que pode ser efeitos adversos sobre ativo da informação.

c) Vulnerabilidade: Fragilidade de hardware que pode propiciar ataque à organização.

d) Alvo: Ativo de informação que pode ser objeto de um ataque/incidente;

e) Ameaças: expectativa de acontecimento acidental ou proposital, causado por um agente, que pode afetar o ambiente, sistema ou ativo da informação.

Anotações



_____
_____
_____
_____
_____
_____
_____
_____
_____
_____

CAPÍTULO 8

PADRÕES DE PROCESSOS

Olá!

Nesse capítulo vamos destacar alguns padrões de segurança que são altamente recomendas para garantir a qualidade dos processos realizados nas empresas. É importante lembrar que os padrões não são direcionados apenas aos sistemas de informação, pois são práticas amplamente aplicadas nas instituições para organização e controle.

Bons estudos!

Prof. Jefferson Ribeiro de Lima



Fala Professor

8.1. Normas e padrões

Quando a produção de bens ou serviço é desenvolvido de acordo com um padrão consolidado no mercado, isso terá efeito de referência para autenticar a qualidade do produto ou serviço. Dentro da área de segurança, foram criados normas e padrões que devem se aplicados para alcançar a qualidade do atendimento e controle na gestão de tecnologia da informação das empresas. Esses padrões, por sua vez, serão destacados a partir deste capítulo.

ITIL

Segundo o site www.itil.org, ITIL (Information Technology Infrastructure Library) é um conjunto de documentos públicos, cuja a finalidade é apoiar a implementação de uma estrutura adequada à gestão de serviço de TI, definindo o escopo de atuação desta estrutura, bem como os seus serviços.

Podemos dizer então que é um conjunto das melhores práticas, não é uma metodologia. Deve ser uma fonte de inspiração que indica como chegar ao resultado esperado.

Embora o ITIL não seja exatamente padrão de segurança, contempla algumas áreas como: incidentes, problemas, implementação e suporte

de software. Desta forma ajuda a padronizar e a melhorar a qualidade dos serviços ofertados pela TI.

Dentre as vantagens da aplicação deste método, podemos citar a redução das ocorrências por falhas operacionais e diminuição no tempo de atendimento a problemas detectados e mais disponibilidade do setor de TI. As ocorrências são catalogadas e a solução será registrada para resoluções futuras de problemas similares.

COBIT

O Cobit (Control objectives for information and related technology) é uma ferramenta que auxiliar o controle das operações realizadas pela TI na empresa. Utiliza normas para a gestão e auditoria de sistemas, o mesmo está dividido em quatro domínios:

- Planejamento e organização;
- Aquisição e implementação;
- Entrega e suporte;
- Monitoração.

O ponto central é o gerenciamento da informação que possui o controle de objetivos, gerando um mapa de auditoria. Também fornece métricas para avaliação de resultados. Cobit disponibiliza uma política para o gerenciamento de TI, no intuito de alcançar as metas da organização.



Logo COBIT
Figura 9 – Logo Cobit

Reflexão

Será que aplicação das normas e padrões implica em uma burocracia excessiva nas empresas? Pode até deixar mais burocrático pelo fato de todos os eventos serem registrados, porém, o ganho para resolução de problemas e qualidade do serviço prestados são inquestionáveis.

BS 7799 e ISO/IEC 17799

A família de padrões BS 7799, trata da gestão de segurança da informação. Foi publicada em 1995, *pela Bristish Standards Institution* e se tornou padrão internacional em 2000. Cada parte do padrão definiu o tipo de segurança. Por exemplo, a segunda parte do padrão BS 7799-2 é voltado para avaliação de riscos de sistemas, esse modelo de certificação de auditoria equivale às normas ISO 9001 voltados para softwares.

Segundo a ISO 17799, as principais fontes para a identificação dos requisitos de segurança são:

- Avaliação de risco dos ativos da organização, para identificação das ameaças, probabilidades de ocorrência e vulnerabilidades, e, estimativa do impacto potencial associado;

- Legislação vigente, estatutos e cláusulas contratuais a que a organização tem que atender;

- Conjunto de princípios, objetivos e requisitos de processamento da informação.



Atenção

A sigla ISO (Organização Internacional de Normalização) é um modelo de gestão de qualidade, que tem por objetivo certificar e qualidade de produtos e serviços ofertados. Atualmente e composta por três normas (9000, 9001 e 9004).

ISO guide 73

Publicada em 2002, define 29 termos da gestão de riscos. Foram agrupados da seguinte forma:

Termos básicos; termos relacionados a pessoas ou organizações; termos relacionados à avaliação de riscos; termos relacionados a tratamento e controle de riscos. A norma é importante a fim de padronizar os conceitos relacionados à gestão de risco.

ISO 13335

Voltado diretamente para os processos de gestão de segurança da tecnologia da informação. E composta por cinco partes, que trata conceitos e

modelos da administração de TI, das técnicas, da seleção de medidas de proteção e da orientação gerencial em segurança de redes.

Indicações



Uma boa fonte de pesquisa para complementar os seus estudos sobre os padrões ISO, podem ser encontrado no link http://www.iso.org.

Atividades



Atividade 8

Trabalho de Pesquisa:

a) Faça uma pesquisa sobre a ISO 13335 e descreva a sua finalidade e aplicabilidade no contexto da gestão de segurança em TI.

Anotações



CAPÍTULO 9

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Olá!

Neste capítulo vamos conhecer e entender a importância da política de segurança e como fazer para diagnosticar possíveis falhas na sua criação. Vamos entender como detectar e reparar possíveis vulnerabilidades dentro do contexto dessa política, através do acompanhamento, monitoramente e testes da aplicação das diretrizes.

Bons estudos!

Prof. Jefferson Ribeiro de Lima



Fala Professor

9.1. Política de segurança

Para a criação da política de segurança, é necessário saber a nível estratégico, quais são os pontos principais da empresa que refletem as áreas mais preocupantes. É de grande importância que o gestor participe do processo para confecção desse documento, pois os mesmos vão indicar setores críticos que detém um alto grau de importância para o funcionamento da empresa. Antes da aprovação deste documento, a direção fará críticas e sugestões que terão impacto direto nas diretrizes que nortearão as normas de segurança.

É importante ressaltar, que esse documento não pode ser estático, deve sofrer atualizações quando necessário, a fim de garantir e responder às frequentes novas ameaças que possam surgir provenientes dos diversos tipos de ambientes, internos ou externos.

9.2. Adoção da PSI

A Política de Segurança da Informação (PSI), deve ser criada no intuito de atender as necessidades de controle, principalmente das informações acessadas pelos usuários nas empresas. Devido a esse fator, o ponto chave deste documento, deve ser direcionado aos princípios

éticos de uso da estrutura da corporação, sem entrar no mérito dos detalhes técnicos da implementação.

Segundo Beal (2005), "é aconselhável que o documento que registra a política de segurança contenha uma declaração introdutória, com o problema da segurança da informação no contexto mais amplo dos riscos do negócio, com explicação da importância da informação e dos recursos computacionais e a necessidade de protegê-los contra as ameaças existentes para prevenir consequências negativas que podem advir da destruição do sistema de informação".

Esse documento deve conter claramente informações a respeito da responsabilidade de uso dos equipamentos e softwares que podem ser utilizados na organização, como também, delegar responsabilidades e penalidades aos usuários que não se orientem pela política de segurança estabelecida.

Cabe também ao manual de PSI, estabelecer as orientações de proteção a serem adotadas por seus usuários. Essas informações podem variar de acordo com a finalidade e tamanho da instituição envolvida.

Reflexão



Não existe "receita de bolo" no processo de auditoria e segurança de sistemas, o segredo está em análise detalhada da organização para definir o melhor método de trabalho para o contexto.

Não existe padrão para a definição da PSI, porém algumas recomendações podem ser úteis na elaboração do documento. A seguir destaco algumas delas:

Articulação da Segurança: Definir responsáveis pela administração das questões relativas a segurança da informação;

Ordenação e controle: Determinação da ordem e classificação das informações relevantes e/ou críticas, para determinação de controles para a sua proteção.

Controle de Usuários: Sem dúvida o item chave para o funcionamento da PSI. Deve ter seus direitos e deveres bem definidos através das diretrizes de segurança pessoal (funcionários e prestadores de serviço), como comportamental (tais como emails, internet, etc.);

Segurança do ambiente físico e lógico: Padrões devem ser definidos para proteção dos recursos físicos e sua instalação do processamento, como também, a proteção do ambiente lógico, garantindo as operações computacionais e a integridade das informações;

Segurança do meio de comunicação: Regra para proteção definida para tráfego de dados na rede interna ou externa a instituição;

Segurança para aquisição, implementação ou manutenção: Diretrizes definidas para aquisição de novos equipamentos ou softwares, para desenvolvimento de aplicações, ou manutenção de equipamentos e/ou serviços lógicos da empresa;

Gerência de negócio: São recomendações para evitar que processos maliciosos neutralizem as atividades da entidade. Meio instrutivo para correção de falhas;

Conformidades: Diretrizes para preservação da conformidade com requisitos legais. São procedimentos a serem adotados em caso de violação da política de segurança.



Atividades

Atividade 9

1) Responda

a) Qual é a importância da aplicação da PSI na empresa?

b) Por que o nível estratégico deve participar da confecção do documento de PSI?

c) Qual é a importância das alterações nesse documento (PSI) ao longo do tempo?

d) Cite alguns tipos de ataques internos que podem comprometer a estrutura de informação da empresa.

e) Cite alguns tipos de ataques externos que podem comprometer a estrutura de informação da empresa.

Atividades



2) Indique (V)verdadeiro ou (F)falso sobre as recomendações para definição da PSI.

( ) Regra para proteção definida para tráfego de dados na rede interna ou externa a instituição, são consideradas, segurança do meio de comunicação.

( ) A Articulação da Segurança são recomendações para evitar que processos maliciosos neutralizem as atividades da entidade.

( ) A determinação da ordem e classificação das informações relevantes e/ou críticas, relaciona-se diretamente com o controle de usuários.

( ) A ordenação e controle é, sem dúvida, o item chave para o funcionamento da PSI.

( ) Definir responsáveis pela administração das questões relativas à segurança da informação. Esse conceito e conhecido como gerência de negócio.

( ) A segurança do ambiente físico e lógico são padrões que devem ser definidos para proteção dos recursos físicos e lógicos.

( ) Diretrizes para preservação da conformidade com requisitos legais. São procedimentos a serem adotados em caso de violação da política de segurança.

CAPÍTULO 10

ASPECTOS HUMANOS DA SEGURANÇA DA INFORMAÇÃO

Olá!

Neste capitulo vamos conhecer como a fragilidade do aspecto humano pode colocar em risco os fatores da segurança da informação nas organizações, e também, conheceremos mecanismos para tentar minimizar as consequências do fato.

Bons estudos!

Prof. Jefferson Ribeiro de Lima



Fala Professor

10.1. Aspectos humanos

Sem dúvida, a melhor prática aplicável no nível do aspecto humano nas organizações é a *trust, but verify* (confie, mas verifique). Apesar da grande parte da atenção dos métodos de seguranças serem direcionados aos ataques ou espionagem por peritos em computação, grande parte dos problemas são gerados por usuários da própria instituição. Esses problemas podem ser de ordem acidental, como também, podem ser provocados de forma intencional com objetivo de prejudicar a empresa.

Não tenha dúvida que o elo mais frágil da empresa, são as pessoas, que por motivos diversos, colocam em risco a integridade e disponibilidade do sistema de informação. Não existe sistema 100% seguro quando há interação com pessoas na organização.

Uma pesquisa realizada pela Ernst e Young (2003), afirma que os maiores prejuízos financeiros são acarretados por incidentes internos da segurança.

Quando se fala em problemas que foram provocados por incidentes internos podemos considerar não apenas os funcionários como também os terceiros, ou chamados prestadores serviços. Grandes partes dos trabalhadores terceiros possuem algum tipo acesso ao sistema de informação da organização.

10.2. Equipe de segurança

Sem dúvida nenhuma, a escolha da equipe da gestão de segurança é primordial para garantir a eficácia do processo. Não adianta possuir os melhores equipamentos, softwares de antivírus, firewall e outros, caso não tenha um administrador capacitado para organizar e gerenciar o ambiente de TI. O profissional desta área deve possuir profundo conhecimento técnico além de ser extremamente ético, caso contrário consequências desastrosas como destruição de dados ou venda de informações confidenciais colocarão a empresa em risco.

10.3. Segurança do núcleo operacional

A segurança dos ativos está ligada diretamente pela colaboração de todos os funcionários da empresa. A prevenção e palavra chave para a reação de eventuais ameaças que poderão surgir. É papel dos colaborares comunicar a ocorrência de novos eventos que possam negligenciar a política de segurança da informação na instituição.

Conceitos



Ativos: São bens e direitos de uma empresa, podemos citar como exemplo: veículos, estrutura física, móveis, concessões de direitos e outros.

Os controles corretivos são criados para minimizar o impacto desse tipo de problema, mas é praticamente impossível prever todas as ocorrências e falhas. Outro ponto importante é o risco de ataques provocados por funcionários. Essa situação deve receber atenção especial, pois dependendo do tipo de acesso desse usuário, o mesmo poderá provocar um grande dano.

Para tentar diminuir os riscos provocados pelo núcleo operacional é recomendado efetuar processos confiáveis de seleção de pessoas, definição das responsabilidades no contrato de trabalho, assinatura de acordos de sigilo e confidencialidade, adequação de segregação de funções, treinamento e conscientização, punição em caso de desrespeito as normas de segurança, processo de desligamento do funcionário do sistema.

10.4. Engenharia social

Normalmente, a engenharia social é algo ignorado na segurança da informação. Através da engenharia social, pessoas más intencionadas obtêm informações confidenciais ou privilegiadas dos usuários, a fim de adquirir algum beneficio ou apenas para denegrir a imagem da pessoa enganada.

As empresas podem passar por esse tipo de problema, pois os usuários são extremantes frágeis e acabam caindo no típico golpe da confirmação dos dados cadastrais. Para evitar esse tipo de golpe é necessário a conscientização e treinamento dos funcionários.



Atenção

Um exemplo típico é o envio de email fazendo-se passar por um banco qualquer. Normalmente o bandido virtual solicita o número da conta e confirmação da senha para atualização dos dados cadastrais. Ao fornecer os dados, o meliante virtual poderá acessar a conta da vítima para efetuar transferências, compras e qualquer outra operação em seu nome.

Segundo Beal (2005), "muitos hackers bem-sucedidos na invasão de sistemas, ao serem entrevistados, admitem ter obtido senhas e outras informações que possibilitaram o ataque pelo uso da engenharia social". Isso quer dizer que grande parte dos funcionários de uma empresa, normalmente não são orientados para lida com esse tipo de golpe, ofertando um grande risco para organização. Caso essa ocorrência seja contemplada pela PSI, o funcionário deve ser punido para evitar novas violações.

Atividades



Atividade 10

1) Responda:

a) Que tipo de problemas podem ser levantados sobre os aspectos humanos relacionados a TI?

b) Cite alguns incidentes comuns ocorridos por funcionários pela má utilização dos computadores da empresa?

c) Qual é o perfil do profissional responsável pela segurança dos dados?

d) Como podemos tentar evitar fraudes ou vazamento de informações na área operacional ou por prestadores de serviços na empresa?

2) Faça uma pesquisa sobre o tema engenharia social.

a) Pesquise e transcreva sobre um caso real ocorrido em uma empresa.

b) Descreva as soluções aplicadas.

CAPÍTULO 11

SEGURANÇA DO AMBIENTE

Olá!

Vamos aprender através deste capítulo a importância da proteção do ambiente físico e lógico. Também conheceremos as práticas aplicadas para elaboração de barreiras preventivas, a fim de proteger o patrimônio da organização.

Bons estudos!

Prof. Jefferson Ribeiro de Lima



Fala Professor

11.1. Segurança do ambiente físico

Para aplicar e adequar o ambiente físico da organização, a fim de manter a segurança física das informações, não é tarefa fácil. A exigência de uma série de medidas que implicam na prevenção de ataques que podem se originar de eventos físicos, lógicos ou ambos.

Segundo a ISO 17799, a expressão perímetro de segurança é definida como "quaisquer elementos que estabeleçam uma barreira ao acesso indevido".

Interpretando essa definição, percebemos que o perímetro de segurança e delimitação da região, em outras palavras zona de segurança. Através da barreira preventiva, é possível garantir a proteção contra ataques físicos ou lógicos à instituição.

Mas o que é um meio físico e lógico? A primeira coisa a entender é que o meio físico representa qualquer objeto concreto na organização. Podemos citar paredes, computadores, sistema elétrico, etc. Já o meio lógico é representado por sistemas computacionais, responsáveis pelo controle das informações e regras de negócios, como acesso aos sistemas e tráfego de dados na rede.

Segundo a ISO 17799, recomendam-se para a segurança física as seguintes diretrizes:

- Perímetro de segurança claramente definido;
- Perímetro de prédios ou locais que contenham recursos de processamento de dados fisicamente consistente;
- Implantação de área de recepção ou outro meio de acesso físico ao local ou prédio e restrição de acesso apenas a pessoas autorizadas;
- Barreiras físicas estendidas da laje do piso até a laje superior, para prevenir acessos não autorizados;
- Portas de incêndio no perímetro de segurança com sensores de alarme e mola para fechamento automático.

A ISO 17779, também menciona como área de risco em especial a expedição e carga, segundo a ISO, as informações utilizadas nesse ambiente devem possuir o caráter de acesso restrito a poucos funcionários. A norma também informa que será necessária uma supervisão constante para prevenir a realização de atividades não autorizadas nesses setores.

11.1.1. Proteção de documentos

Ainda é muito comum a utilização de documentos em papel por parte das empresas. Fazer a proteção desse documento implica na elaboração de procedimentos a fim de garantir o mínimo de segurança.

Dentre os elementos que devem ser controlados podemos citar: cópias, armazenamento, transmissão de correio e descarte.

Reflexão



Normalmente os procedimentos para proteção e controle de documentos não são vistos com a importância necessária para o funcionamento da instituição.

Como consequência dessa falta de cuidado, os prejuízos ou danos podem se tornar imprevisíveis. Por exemplo, o descarte sem o cuidado especial de uma informação sigilosa, pode acarretar um ato de espionagem efetuado por terceiros ou até mesmo funcionários.

Dentre os mecanismos que podem ser criados para o melhor controle desses documentos, podemos citar: a inserção de rótulos para identificação dos mesmos, o controle sobre documentos impressos ou via fax e a política de armazenamento de papéis que assegure a guarda em local protegido.

11.1.2. Proteção de mídias

Da mesma forma que o documento de papel deve ser protegido, as mídias digitais devem ser resguardadas contra roubo e armazenadas em local seguro conforme orientação do fabricante.

A remoção, descarte ou manuseio devem ser feitos de acordo com os procedimentos planejados e executados apenas por pessoas autorizadas. Mídias que forem levadas para ambientes externos devem seguir as normas estabelecidas pela empresa.

11.1.3. Proteção de hardware

Para efetuar a proteção de hardware nas instituições, será necessário criar uma política de segurança que contemple o controle do patrimônio da empresa. O controle de patrimônio, além de garantir o registro dos equipamentos, irá coibir o deslocamento dos computadores e qualquer outro tipo de propriedade da empresa sem prévia autorização.

Mas, além de proteger é necessário preservar, devido isso, além de garantir uma política de segurança dos equipamentos é indispensável definir regras claras para o seu manuseio. Desta forma, será possível minimizar os prejuízos acarretados pela má utilização dos funcionários.

Outro controle importante para garantir a segurança do hardware na instituição e definindo o responsável pelo uso. Desta forma, será possível monitorar eventos que ocorram por usuários/equipamentos. Mas nada disso funciona, caso não exista na empresa o controle de acesso físico aos meios disponíveis.

Na prevenção do hardware, a falta de energia é um fator altamente relevante, pois poderá ocasionar prejuízos à instituição. Para evitar possíveis perdas de dados ou defeitos aos equipamentos, é necessário criar um plano de contingência, reduzindo desta forma, possíveis imprevistos gerados pela falta de energia.

- O cabeamento (elétrico, telefônico e computadores) utilizado nas empresas é, sem dúvida, outra preocupação para os gestores.

- Sobre o cabeamento, a ISO 17779, **recomenda** os seguintes controles para cabeamento elétrico e de telecomunicação:

- Usar, sempre que possível, linhas elétricas e de telecomunicação subterrâneas, ou pelo menos sujeitas à proteção alternativa;

- Cabeamento de rede protegido contra interceptações não autorizadas ou danos;

- Cabos elétricos separados dos cabos de comunicação para prevenir interferências;

- Controles adicionais para sistemas críticos.

11.2. Segurança do ambiente lógico

Apesar de todas as dificuldades para proteção do ambiente físico, sem dúvida, pode-se afirmar que o ambiente lógico requer o dobro de proteção para tentar garantir a segurança das informações.

Mas, o que é o ambiente lógico?

O ambiente lógico são programas e/ou aplicativos que serão utilizados nos computadores da empresa. Tem como finalidade proteger, processar, trafegar e armazenar o fluxo de dados que serão fornecidos por seus usuários.

O grande problema para proteção do meio lógico é a dificuldade em se identificar as falhas, para que as medidas preventivas possam ser aplicadas. Podemos citar como exemplo, um único usuário, que pode colocar em risco toda estrutura lógica da empresa, caso não tome as medidas de segurança necessárias definidas pela PSI (Política da Segurança da Informação) da empresa.

Por mais que se tente controlar o meio lógico, caso a empresa tenha conexão à rede mundial de computadores (Internet), não será possível garantir que as falhas de vulnerabilidades apareçam, devido às rápidas mudanças que ocorrem na tecnologia.

11.2.1. Proteção do ambiente lógico

Não existe um padrão definido quando o assunto é segurança no ambiente lógico. Cada caso deve ser analisado de forma independente, a fim de minimizar as falhas. Por exemplo, os softwares que controlar a

rede de computadores no ambiente empresarial devem ser cercados de aparatos de segurança, garantindo acesso às informações somente a pessoas autorizadas. É comum que cada usuário tenha um login e senha, ao qual será definido seu nível de independência aos sistemas, garantindo o monitoramento que será efetuado pelo gestor da rede.

Outros programas como firewall, antivírus e Proxy devem se instalados e atualizados rotineiramente, pois são ferramentas primordiais na gestão de segurança do ambiente lógico.

Segundo Wikipédia,



Conceitos

Antivírus: são softwares projetados para detectar e eliminar vírus de computador.

Firewall: (em português: Corta-fogo) é o nome dado ao dispositivo de uma rede de computadores que tem por objetivo aplicar uma política de segurança a um determinado ponto de controle da rede. Sua função consiste em regular o trajeto, o tráfego de dados entre redes distintas e impedir a transmissão e/ou recepção de acessos nocivos ou não autorizados de uma rede para outra. Existe na forma de software e hardware, ou na combinação de ambos (neste caso, normalmente é chamado de "appliance").

Proxy: é um servidor que atende a requisições repassando os dados do cliente à frente. Um usuário (cliente) conecta-se a um servidor proxy, requisitando algum serviço, como um arquivo, conexão, website, ou outro recurso disponível em outro servidor.

Os programas que controlam o fluxo de informações adotados nas empresas devem possuir seu próprio aparato de segurança, além dos softwares já pré-instalados nas plataformas de trabalho. Recursos como criptografia e controle de acesso, normalmente são acoplados nesse tipo aplicação. Mas tudo isso ainda não garante que os usuários mal intencionados tentem burlar os mecanismos de segurança implementados no sistema.

11.2.2. Perímetro de segurança do ambiente lógico

Perímetro como já sabemos é uma zona delimitada cercada de máxima segurança, porém, no ambiente lógico é difícil de ser implementada em função das dificuldades para detecção de falhas. O software que normalmente é utilizado para efetuar esse serviço é o firewall, juntamente às regras de controle de acesso, mas outros programas como antivírus e Proxy podem tornar mais difíceis às possibilidades de ataques ao perímetro. Entretanto, é impossível garantir que o ambiente seja 100% (cem por cento) seguro de falhas.

11.3. Controle de acesso

O controle de acesso consiste em garantir a segurança do meio físico e lógico dos processos da organização. Cada colaborador deve possuir restrições bem definidas de acordo com seu cargo e responsabilidade, para garantir que pessoas desautorizadas não tenham acesso a informações privilegiadas.

11.3.1. Proteção do controle físico

A proteção física é mais simples de se aplicar, pois é possível definir através de cargos e hierarquias quais serão os limites de cada funcionário dentro do perímetro. Existem inúmeros aparatos de segurança que podem garantir a eficiência deste controle. Mecanismos como crachás, reconhecimento biométrico, câmeras de segurança e outros podem ser aplicados para garantir o acesso físico dos colaboradores. O grande problema relativo a esse tipo controle está no custo de instalação e manutenção, entretanto é um mal necessário para grande maioria das organizações.

11.3.2. Proteção do controle lógico

Sem dúvida, a proteção do controle lógico é a mais traumática, pois conforme comentado no tópico 11.2.1 - proteção no ambiente lógico, é difícil prever todas as falhas existentes nos softwares. Por mais que a empresa possua especialistas em segurança na área de tecnologia da informação é praticamente impossível prever todas as vulnerabilidades dos sistemas em uso.

Alguns recursos recebem mais atenção dos consultores de segurança como: sistemas corporativos, arquivos de dados e sistemas operacionais, mas isso não impede que qualquer uma das categorias de softwares ci-

tados tenha brechas em sua segurança. Porém, o mais importante no controle do ambiente lógico é definir o que cada colaborador terá acesso no seu domínio de trabalho. Esse tipo de restrição deve ser definido no nível de software por um profissional habilitado.

O gestor de TI tem autonomia para definir quais serão as ferramentas e ações (gravação, leitura, deleção, impressão, etc.) utilizadas para cada colaborador de acordo com a política de segurança da informação e de acordo com os seus respectivos cargos /hierarquias.



Conceitos

Sistemas corporativos: São softwares projetados para atender a rotina diária das organizações. Esses softwares podem atender a mais de uma empresa do mesmo setor, quando isso ocorrer é denominado software de pacote. Quando criado para atender a necessidade específica de uma empresa, é chamado sistema fechado. Sistemas fechados são mais caros do que os softwares de pacote, pois são customizados.

Arquivos de dados: São os arquivos responsáveis em armazenar o fluxo de informações, processados pelos sistemas corporativos. Atualmente os SGBD (Sistemas Gerenciadores de Banco de Dados) são responsáveis sem efetuar essa tarefa, atribuído os controles necessários para garantir a segurança no armazenamento e recuperação das informações.

Sistemas Operacionais: São softwares responsáveis em colocar a máquina em funcionamento, além disso, possuem uma série de processos essenciais para a execução das tarefas realizadas. Podemos dizer que é, sem dúvida, o cérebro ou o coração do computador; sem ele o usuário não acessa a rede, não abre arquivo, não imprime o dado, não acessa a internet, dentre outros.

Atividades

Atividade 11

1) Responda:

a) Quais são os mecanismos aplicados para garantir a segurança dos meios físicos e lógicos?

b) Quais são os erros mais comuns ao manusear documentos nas empresas?

c) Comente como a proteção das mídias pode ser efetuada?

d) Descreva o porquê o controle patrimonial é importante?

e) Que tipo de plano de contingência é o mais adequado caso haja falta energia na empresa?

f) Por que o ambiente lógico necessita de mais proteção?

g) Qual é a importância em se criar conta de acesso no sistema para cada usuário?

h) Quais são os programas mais comuns utilizados para proteção do ambiente lógico?

i) Cite algumas aplicações lógicas primordiais para o funcionamento da empresa?

j) Descreva qual é o papel do gestor da tecnologia da informação no ambiente lógico?

2) Complete com (V) verdade ou (F) falso:

( ) O ambiente físico trata os softwares e regras de negócios da empresa.

( ) Ao tratar a parte física da empresa é necessário proteger: hardware, mídias e documentos.

( ) O perímetro de segurança é setor da empresa responsável pelo controle de acesso.

( ) O trafegar de informações na rede é efetuado pelo controle lógico.

3) Relacione:

1) Lógico

2) Físico

( ) Controle patrimonial na empresa.

( ) Dificuldade para encontrar falhas.

( ) Efetuar conexão com a rede mundial dos computadores.

( ) Perímetro de segurança na empresa.

Referências Bibliográficas

CESAR, Ricardo. **Quando os dados mentem**. Revista Computerwold, 2005.

BEAL, Adriana. **Segurança da Informação: Princípios e melhores práticas para proteção dos ativos de informação nas organizações**. Ed. Atlas. 2005

Padrões 17999. Disponível em <http://www.iso.org/iso/home.htm>. Acesso em: 05 out. 2009.

ARIMA, Carlos Hideo. **Metodologia de auditoria de sistemas**.São Paulo: Érica, 2007.

IMONIANA, Joshua Onome. **Auditoria de sistemas de informação** – São Paulo: Atlas, 2008.

GIL, Antônio de Loureiro. **Auditoria de Computadores**. 5.ed. Atlas, 2000.

DIAS, Cláudia. **Segurança e auditoria da tecnologia da informação**. Rio de Janeiro: Ed. Axcel Books, 2000.